

Protection of Information Assets

FLORENCE LOVE NKOSI, CISA|CEH

ICT @ Mzuni

Reference Books

- All in one CISA guide chapter 6
- CISA review Manual

ICT @ Mzuni

Information assets

- An information asset is a component related to provision of accurate data or information for decision making purposes by an entity.
- It is considered to hold value to that particular organization and should therefore be protected by ensuing **Confidentiality, integrity and availability (CIA).**

ICT @ Mzuni

Information Security Management Systems (ISMS)

- Represents the collation of all the interrelated/interacting information security elements of an organization so as to ensure policies, procedures, and objectives can be created, implemented, communicated, and evaluated to better guarantee an organization's overall information security
- This system is typically influenced by the organization's needs, objectives, security requirements, size, and processes
- Includes and leads to effective risk management and mitigation strategies

ICT @ Mzuni

INFORMATION Security Management

- Information security management is probably the most important precondition for effective protection of information assets and privacy.
- There are several reasons for this. ISM:
  - Supports security awareness and education (policies, procedures, audits, videos, training simulations, updates, enforcement of security…)
  - Ensures compliance with laws, regulations and standards
  - Upholds the CIA triad (Confidentiality, Integrity and Availability)
  - Ensures protection of sensitive data

ICT @ Mzuni

Key elements of Information security management

- An ISMS is defined in the International Organization for Standardization (ISO)/International Electro-Technical Commission (IEC) 27000 series of standards and guidelines
- ISO 27000 series is as follows:
  - ISO 27001
  - ISO 27002
  - ISO 27003
  - ISO 27004
  - ISO 27005

Critical Success Factors to Information Security Management

1. Security Awareness, Training, and education

   Security awareness program should include the following:

   - Training (often administered online)
   - Quizzes to gauge retention of training concepts
   - Security awareness reminders such as posters, newsletters or screensavers
   - A regular schedule of refresher training

Critical Success Factors to Information Security Management

2. Strong leadership, direction, and commitment by senior management on security training are needed.
   - This commitment should be supported by a comprehensive program of formal security awareness training.
3. A professional risk-based approach must be used systematically to identify sensitive and critical information resources and to ensure that there is a clear understanding of threats and risks.
   - Thereafter, appropriate risk assessment activities should be undertaken to mitigate unacceptable risk and ensure that residual risk is at an acceptable level

Auditing information security management

Auditing information security framework of an organization involves the audit of logical access, testing security and using various techniques to ensure that frameworks are being wel implemented.

Auditing information security management

- Auditing information security management may involve looking and reviewing the following:
  - Reviewing policies and procedures
  - Logical access control
  - Formal security
  - Data ownership
  - Data custodians
  - New IT users
  - Documented authorization
  - Terminated employee access
  - Access standards

ICT @ Mzuni

The classification of Information assets

- Effective control requires a detailed inventory of information assets.
- Creating this list is the first step in classifying assets and determining the level of protection needed for each asset.
- Information assets have varying degrees of sensitivity and criticality in meeting business objectives
- Classification of information assets reduces the risk and cost of over- or under-protecting information resources in linking security to business objectives because it helps to build and maintain a consistent perspective of the security requirements for information assets throughout the organization
- Most organizations use a classification scheme with three to five levels of sensitivity.

The classification of Information assets

HIGHLY RESTRICTED

This classification label applies to the most private or otherwise sensitive information of the Company. Information under this classification shall be strictly monitored and controlled at all times.

Examples merger and acquisition documents, corporate-level strategic plans, litigation strategy memos, reports on breakthrough new product research, and Trade Secrets such as certain computer programs.

CONFIDENTIAL

This classification label applies to Company information, which is private or otherwise sensitive in nature and shall be restricted to those with a legitimate business need for access.

Examples: employee performance evaluations, customer transaction data, strategic alliance agreements, unpublished internally generated market research, computer passwords, identity token personal identification numbers (PINs), and internal audit reports).

INTERNAL USE ONLY

This classification label applies to information intended for use within the Company, and in some cases, within affiliated organizations, such as business partners of the Company.

Assets of this type are widely-distributed within the Company and may be distributed within the Company without permission from the information asset owner. (e.g., telephone directory, dial-up computer access numbers, new employee training materials, and internal policy manuals.

PUBLIC

This classification applies to information that has been explicitly approved by the Company's management for release to the public.

Assets of this type may be circulated without potential harm. (e.g., product and service brochures, advertisements, job opening announcements, and press releases.)

ICT @ Mzuni

The classification of Information assets

- The number of classification categories should take into consideration the size and nature of the organization and the fact that complex schemes may become too impractical to use.
- Data classification is a major part of managing data as an asset.
- Data classification as a control measure should define:
  - The importance of the information asset
  - The information asset owner
  - The process for granting access
  - The person responsible for approving the access rights and access levels
  - The extent and depth of security controls

ICT @ Mzuni

Information Security Control design

- Information security is maintained through the use of controls
- Controls can be designed as:
  - Every organization has some controls in place, and a risk assessment should document these controls and their effectiveness in mitigating risk
  - Effective control is one that prevents, detects and/or contains an incident and enables recovery from an event

ICT @ Mzuni

Types of controls

- Controls within the above groups can be classified into:
  - **Preventive controls** – internal controls which are deployed to prevent the happening of an event that might affect the achievement of organizational objectives
  - **Detective controls** – Detective controls seek to identify when preventive controls were not effective in preventing errors and irregularities, particularly in relation to the safeguarding of assets.
  - **Corrective controls** – When detective control activities identify an error or irregularity, corrective control activities should then see what could or should be done to fix it, and hopefully put a new system in place to prevent it the next time around.

ICT @ Mzuni

CATEGORIES OF CONTROLS

Managerial controls – Controls related to the oversight, reporting, procedures, and operations of a process.

These include policy, procedures, balancing, employee development, and compliance reporting.

Technical controls – Controls, also known as logical controls and are provided through the use of technology, a piece of equipment or device.

Examples include firewalls, network or host-based intrusion detection systems (IDSs), passwords, and antivirus software. Technical control requires proper managerial (administrative) controls to operate correctly.

Physical controls – Controls that are locks, fences, closed-circuit TV (CCTV), and devices that are installed to physically restrict access to a facility or hardware.

Physical controls require maintenance, monitoring, and the ability to assess and react to an alert should a problem be indicated.

ICT @ Mzuni

System Access Permission

- System access permission is the prerogative/ power to act on a computer resource.
- This usually refers to a technical privilege, such as the ability to read, create, modify or delete a file or data; execute a program, or open or use an external connection
- System access to computerized information resources is established, managed and controlled at
  - The physical level i.e The use of badges, biometric, cards to enter a building or particular areas in the building
  - The logical level i.e controls over transactions in a system, who can view what functions

ICT @ Mzuni

System Access Permission

- The IT Assets that are being protected can be grouped into four logical layers
  - Networks
  - Platforms
  - Databases
  - Applications
- The information owner should determine who is allowed to have access. Often this should be in a form of written authorizations.
- Reviews of access authorizations should be evaluated regularly.

Mandatory Access and discretionary access controls

- IT security strategy involves implementing an appropriate level of access control to all computer systems in an organization or enterprise.

Mandatory Access and discretionary access controls

Mandatory Access Controls (MACs):

- MACs are logical access control filters used to validate access credentials that cannot be controlled or modified by normal users or data owners; they act by default
- With mandatory access control, the security policy is centrally controlled by a security policy administrator; users do not have the ability to override the policy and, for example, grant access to files that would otherwise be restricted

Discretionary Access Controls (DACs):

- Discretionary Access Control (DAC) allows each user to control access to their own data
- This would be the case of data owner-defined sharing of information resources, where the data owner may select who will be enabled to access his/her resource and the security level of this access.
- DACs cannot override MACs; DACs act as an additional filter, prohibiting still more access with the same exclusionary principle.
- Used in Windows to control who has the read, write execute functionality.

Role Based Access Control

- Role Based Access Control (RBACtakes more of a real world approach to structuring access control.
- Access under RBAC is based on a user's job function within the organization to which the computer system belongs.
- Essentially, RBAC assigns permissions to particular roles in an organization.
- Users are then assigned to that particular role. For example, an accountant in a company will be assigned to the *Accountant* role, gaining access to all the resources permitted for all accountants on the system. i.e Linux groups and roles

ICT @ Mzuni

Other types of Access controls

- **Rule-based access control (RAC)** – Dynamically assign rules to users based on criteria defined by owner or system administrator
- **Organization-based access control (OrBAC)** – allows the policy designer to define a security policy independently of the implementation

ICT @ Mzuni

Logical system access controls

- Logical access control is the means by which organizations implement security constraints over proprietary data and broader digital environments.
- Restrict the logical resources of the system (transactions, data, programs, applications) and are applied when the subject resource is needed.
- Also defined as: Logical access control tools are used for credentials, validation, authorization, and accountability in an infrastructure and the systems within
- On the basis of Identification and Authentication of the user that requires a given resource and by analyzing the security profiles of the user and the resource, it is possible to determine if the requested access is to be allowed (i.e., what information users can utilize, the programs or transactions they can run, and the modifications they can make).
- Such controls may be built into the operating system (OS), invoked through separate access control software and incorporated into application programs, database systems, network control devices, and utilities (e.g., real-time performance monitors).

ICT @ Mzuni

Logical system access controls

- Logical access controls Include:
  - passwords,
  - Encryption
  - Firewalls
  - intrusion detection systems

ICT @ Mzuni

Identification and Authentication

- Authentication is typically categorized as “something you know” (e.g., password), “something you have” (e.g., token card) and “something you are (or do)” (a biometric feature).
- These techniques can be used independently or in combination to authenticate and identify a user. For example, a single-factor technique (something you know) involves the use of the traditional logon ID and password.
- Something you know, such as a pin number, combined and associated with something you have, such as a token card, is known as a two-factor authentication technique. Something you are is a biometric authentication technique, such as a palm or iris biometric scan.

ICT @ Mzuni

Identification and Authentication

Common vulnerabilities to gain unauthorized access include:

- Weak authentication methods
- Bypassing authentication i.e Using SQL injection
- Lack of confidentiality and integrity for the stored authentication information
- Lack of encryption for authentication and protection of information transmitted over a network
- User's lack of knowledge on the risks associated with sharing passwords, security tokens, etc.

ICT @ Mzuni

Identification and Authentication - Passwords

Features of Passwords

- A secret combination of words and numbers used together with a username inorder to log into a system
- A password should be easy for the user to remember but difficult for a perpetrator to guess. Initial passwords may be allocated by the security administrator or generated by the system itself.
- When the user logs on for the first time, the system should force a password change to improve confidentiality.
- If the wrong password is entered a predefined number of times, typically three, the logon ID should be automatically and permanently deactivated (or at least for a significant period of time).

Token Devices, One-Time Passwords:

- A two-factor authentication technique, such as a microprocessor-controlled smart card, generates one-time passwords that are good for only one logon session.
- Users enter this password along with a password they have memorized to gain access to the system.
- This technique involves something you have (a device subject to theft) and something you know (a personal identification number). Such devices gain their one-time password status because of a unique session characteristic (e.g., ID or time) appended to the password.

ICT @ Mzuni

Identification and Authentication - Passwords

Token Devices, One-Time Passwords:

- A two-factor authentication technique, such as a microprocessor-controlled smart card, generates one-time passwords that are good for only one logon session.
- Users enter this password along with a password they have memorized to gain access to the system.
- This technique involves something you have (a device subject to theft) and something you know (a personal identification number). Such devices gain their one-time password status because of a unique session characteristic (e.g., ID or time) appended to the password.

Identification and Authentication

Biometrics

- Biometric access controls are the best means of authenticating a user's identity based on a unique, measurable attribute or trait for verifying the identity of a human being.
- This control restricts computer access, based on a physical (something you are) or behavioral (something you do) characteristic of the user.
- Management of biometrics should address effective security for the collection, distribution and processing of biometric data, Management should develop and approve biometric information management and security (BIMS) policy.
- The auditor should use the BIMS policy to gain a better understanding of the biometric systems in use.

INDENTIFICATION AND AUTHENTICATION BEST POLICIES

- Disable system accounts
- Do not use default usernames and passwords
- Unused accounts should be deactivated after an agreed period of time
- Automatic disconnection of an idle login session
- Minimum length of password, usually eight characters
- Complex password – combination of words and letters(The longer and complicated the password the more difficult it is to get cracked.

ICT @ Mzuni

Auditing logical access

- Obtain a general understanding of the security reisks facing information processing by looking at relevant documentation ,inquiry and observations, risk assesment and evaluation techniques.
- Document and test controls
- Evaluate the access control environment to see if control objectives are being met
- Evaluate the security environment to assess adequancy by reviewing written policies and observing practices and procedures

Environmental Issues and Exposures

Total failure (blackout)—A complete loss of electrical power, which may span from a single building to an entire geographical area and is often caused by weather conditions (e.g., storm, earthquake) or the inability of an electrical utility company to meet user demands (e.g., during summer months)

Severely reduced voltage (brownout)—The failure of an electrical utility company to supply power within an acceptable range. Such failure places a strain on electronic equipment and may limit their operational life or even cause permanent damage.

Sags, spikes and surges—Temporary and rapid decreases (sags) or increases (spikes and surges) in voltage levels. These anomalies can cause loss of data, data corruption, network transmission errors or physical damage to hardware devices (e.g., hard disks or memory chips).

Electromagnetic interference (EMI)—Caused by electrical storms or noisy electrical equipment (e.g., motors, fluorescent lighting, radio transmitters). This interference may cause computer systems to hang or crash as well as damages similar to those caused by sags, spikes and surges.

ICT @ Mzuni

Controls for Environmental exposures

- Short-term interruptions, such as sags, spikes and surges, which last from a few millionths to a few thousandths of a second, can be prevented by using properly placed surge protectors.
- Intermediate-term interruptions, which last from a few seconds to 30 minutes, can be controlled by UPS devices. Finally, long-term interruptions, which last from a few hours to several days, require the use of alternate power generators.
- These generators may be portable devices or part of the building's infrastructure and are powered by alternative sources of energy such as diesel, gasoline or propane.
- Other controls
  - Alarm control panels
  - Water detectors
  - Handheld fire extinguishers
  - Manual fire alarms
  - Smoke detectors
  - Fire suppression systems
  - Strategically locating the computer room
  - Regular inspection by fire department

ICT @ Mzuni

Controls for Environmental exposures

- Fireproof walls, floors and ceilings of the computer room
- Electrical surge protectors
- Uninterruptible power supply / generator
- Emergency power-off switch
- Power leads from two substations
- Wiring placed in electrical panels and conduit
- Inhibited activities within the IPF
- Fire-resistant office materials
- Documented and tested emergency evacuation plans

ICT @ Mzuni

AUDITING ENVIRONMENTAL CONTROLS

- An IS auditor's first concern should be to establish the environmental risk by assessing the location of the data center/ clients office.
- Higher risk items have a greater need for specific environmental controls.

ICT @ Mzuni

Physical Access Issues and Exposures

- Unauthorized entry
- Damage, vandalism or theft to equipment or documents
- Copying or viewing of sensitive or copyrighted information
- Alteration of sensitive equipment and information
- Public disclosure of sensitive information
- Abuse of data processing resources
- Blackmail

ICT @ Mzuni

Physical Access Issues and Exposures

Possible perpetrators include employees who are:

- Disgruntled
- On strike
- Threatened by disciplinary action or dismissal
- Addicted to a substance or gambling
- Experiencing financial or emotional problems
- Notified of their termination

ICT @ Mzuni

Physical controls:

- The controls restrict the entry and exit of personnel to an area such as an office building, suite, data center, or room containing information processing equipment such as a local area network (LAN) server.
- There are many types of physical access controls, including badges, memory cards, guard keys, true floor-to-ceiling wall construction fences, locks, and biometrics.

ICT @ Mzuni

Physical Access Controls

- **Bolting door locks** —These locks require the traditional metal key to gain entry. The key should be stamped “do not duplicate.” Combination door locks (cipher locks)—This system uses a numeric key pad or dial to gain entry. The combination should be changed at regular intervals or whenever an employee with access is transferred, fired or subject to disciplinary action. This reduces the risk of the combination being known by unauthorized people.
- **Electronic door locks —** This system uses a magnetic or embedded chip-based plastic card key or token entered into a sensor reader to gain access. A special code internally stored in the card or token is read by the sensor device that then activates the door locking mechanism.
- **Biometric door locks** —An individual’s unique body features, such as voice, retina, fingerprint or signature, activate these locks. This system is used in instances when extremely sensitive facilities must be protected, such as in the military.

ICT @ Mzuni

Physical Access Controls

- **Manual logging** — All visitors should be required to sign a visitor's log indicating their name, company representative, reason for visiting and person to see. Logging typically is at the front reception desk and entrance to the computer room. Before gaining access, visitors should also be required to provide verification of identification, such as a driver's license, business card or vendor identification tag.
- **Electronic logging** —This is a feature of electronic and biometric security systems. All access can be logged, with unsuccessful attempts being highlighted.
- **Identification badges (Photo IDs) —**Badges should be worn and displayed by all personnel. Visitor badges should be a different color from employee badges for easy identification. Sophisticated photo IDs can also be utilized as electronic card keys. Issuing, accounting for and retrieving the badges is an administrative process that must be carefully controlled.

ICT @ Mzuni

Physical Access Controls

- **Video cameras** — Cameras should be located at strategic points and monitored by security guards. Sophisticated video cameras can be activated by motion. The video surveillance recording should be retained for possible future playback.
- **Security guards—Guards** are very useful if supplemented by video cameras and locked doors. Guards supplied by an external agency should be bonded to protect the organization from loss.
- **Controlled visitor access**— All visitors should be escorted by a responsible employee. Visitors include friends, maintenance personnel, computer vendors, consultants (unless long-term, in which case special guest access may be provided) and external auditors.
- **Bonded personnel —**All service contract personnel, such as cleaning people and offsite storage services, should be bonded. This does not improve physical security but limits the financial exposure of the organization.
- **Deadman doors —**This system, which uses a pair of (two) doors, is typically found in entries to facilities such as computer rooms and document stations. For the second door to operate, the first entry door must close and lock, with only one person permitted in the holding area. This reduces the risk of piggybacking, when an unauthorized person follows an authorized person through a secured entry.

ICT @ Mzuni

Physical Access Controls

- **Controlled single entry point** —A controlled entry point monitored by a receptionist should be used by all incoming personnel. Multiple entry points increase the risk of unauthorized entry. Unnecessary or unused entry points should be eliminated or deadlocked.
- **Alarm system** —An alarm system should be linked to inactive entry points, motion detectors, and the reverse flow of enter- or exit-only doors. Security personnel should be able to hear the alarm when activated.
- **Secured report/document distribution cart** —Secured carts, such as mail carts, should be covered and locked and should not be left unattended
- **Windows** – Ideally the computer room should not have externally facing windows: where these are present, they should be constructed of reinforced glass and, if on the ground floor of the building, further protected for example, by bars

ICT @ Mzuni

Auditing Physical Access Control

- Touring the information processing facility (IPF) is useful to gain an overall understanding and perception of the installation being reviewed.
- Much of the testing of physical safeguards can be achieved by visually observing the previously noted safeguards.
- Documents to assist with this effort include emergency evacuation procedures, inspection tags (recent inspection?), fire suppression system test results (successful? recently tested?) and key lock logs (all keys accounted for and not outstanding to former employees or consultants?).

ICT @ Mzuni

Auditing Physical Access Control

- Testing should extend beyond the information processing facility/computer room to include the following related facilities:
  - Location of all operator consoles
  - Printer rooms
  - Computer storage rooms (this includes equipment, paper and supply rooms)
  - UPS/generator
  - Location of all communications equipment identified on the network diagram
  - Tape library
  - Off-site backup storage facility
- To complete a thorough testing, the IS auditor should look above the ceiling panels and below the raised floor in the computer operations center, observing smoke and water detectors, general cleanliness and walls that extend all the way to the real ceiling (not just the fake/suspended ceiling).

Storing, Retrieving, Transporting and Disposing of Confidential Information

Backup files of databases

- Backup files onto magnetic tapes are often unencrypted, so that even secret information may be obtained by simply loading backup databases to other systems for data analysis.
- Security problems of data media storage and transportation technologies involve ensuring that contractors used to transport and store backup tapes have adequate policies and procedures to protect the integrity and confidentiality of the information.

Data banks

- Research and commercial institutions collect the result of important survey or research projects on large tape libraries (i.e., geodynamic data).
- These data have a high commercial value and may be subject to a requirement of availability and confidentiality that persist for many years, longer than the duration of the media containing them.

ICT @ Mzuni

Storing, Retrieving, Transporting and Disposing of Confidential Information

Disposal of media previously used to hold confidential information —

- **Procedures** should be implemented to identify and erase the sensitive information and software inside computers, disks and other equipment or media that have been identified for disposal so that deleted data may not be retrieved by any internal or third party.
- Care must be taken not only to meet the requirements of data protection, but also when a machine is transferred to another user.
- The original user should remove any personal data that are not confidential by nature.
- If previously held data were sensitive, the disk should be reformatted and then a secure wipe of the disk should be carried out with appropriate utility software.

Storing, Retrieving, Transporting and Disposing of Confidential Information

Management of equipment sent for offsite maintenance

- Data files and proprietary software should be backed up, so that they can be erased from the equipment prior to sending it offsite for maintenance (e.g., computers, PDAs, miniature hard/flash drives).
- Computers holding confidential data should not be sent out for repair, unless memories are withheld.

Storing, Retrieving, Transporting and Disposing of Confidential Information

E-token electronic keys

- For such sensitive information, data transportation on floppy and hard disks is not safe and should not be used.
- Taking proper care of the media can significantly reduce the chances of data loss.

Storage records

- Many commercial organizations fulfill legal or institutional obligations to preserve specific types of records, which may be confidential in nature, for a given number of years, by outputting microfiche images of the related documents.

Storing, Retrieving, Transporting and Disposing of Confidential Information

Other factors to consider:

- Preserving information during shipment or storage
- Recommendations applicable to all types of media
- Keep out of direct sunlight
- Keep free of liquids
- Keep free of dust
- Keep media away from exposure to magnetic fields, radio equipment or any sources of vibration
- Do not transport in areas and at times of exposure to strong magnetic storm

ICT @ Mzuni

Network Infrastructure

- Network infrastructure devices are the components of a network that transport communications needed for data, applications, services, and multi-media.
- These devices include routers, firewalls, switches, servers, load-balancers, intrusion detection systems, domain name systems, and storage area networks.

ICT @ Mzuni

AUDITING NETWORK INFRASTRUCTURE

- Review network diagrams (campus LAN networks, WANS, metropolitan area networks [MANs]) that identify the organizations internetworking infrastructure, which would include gateways, firewalls, routers, switches, hubs, access servers, modems, etc. This information is important because the IS auditor will want to evaluate these links to determine whether proper physical and logical access controls are in effect and to inventory the various terminal connections to ensure that the diagram is accurate.
- Identify the network design implemented, including the IP strategy used, segmentation of routers and switches for campus environments, and WAN configurations and protocols.
- Determine that applicable security policies, standards, procedures and guidance on network management and usage exist and have been distributed to staff, network management and administration. He/she should also ensure that staff members have been trained in their duties and responsibilities.
- Identify who is responsible for security and operation of Internet connections, and evaluate whether they have sufficient knowledge and experience to undertake this role.

ICT @ Mzuni

AUDITING NETWORK INFRASTRUCTURE

- Review network administrator procedures to ensure that hardware and software components are upgraded in response to new vulnerabilities.
- Review the transmission medium used for the LAN and its physical security protection to establish vulnerability to wiretapping.
- Review the network topological design to ensure it is sufficiently resilient to maintain business continuity in the event of disruption (e.g., a ring network is more resilient than a star).
- Review the network design to identify single points of failure, such as all WAN connections

ICT @ Mzuni

Computer crime issues and exposures

- Computer systems can be used to fraudulently obtain money, goods, software or corporate information.
- Crimes can also be committed when the computer application process or data are manipulated to accept false or unauthorized transactions.
- Computer crime can be performed without anything physically being taken or stolen, and it can be done remotely.
- A computer can be used: to commit crime, can be evidence of the crime or fruits of the crime.



Computer crime issues and exposures

The effects of computer crime can result into:

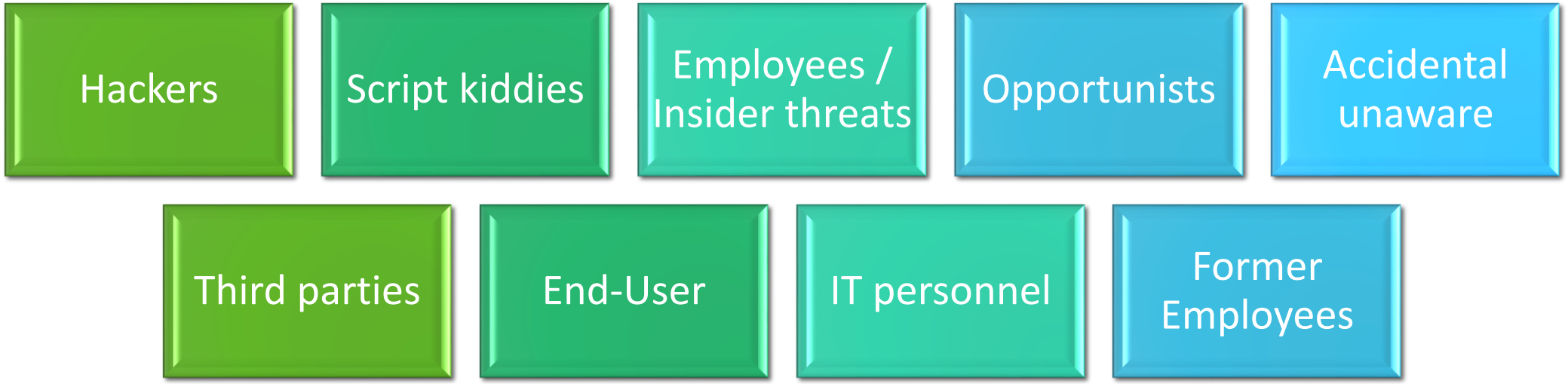
- Financial loss
- Legal consequences
- Loss of credibility
- Blackmail
- Disclosure of confidential information



ICT @ Mzuni

Perpetrators in computer crimes

- Perpetrators in computer crimes are often the same people who exploit physical exposures, although the skills needed to exploit logical exposures are more technical and complex.



Perpetrators in computer crimes

Hackers

- Persons with the ability to explore the details of programmable systems and the knowledge to stretch or exploit their capabilities, whether ethical or not.
- Hackers are typically attempting to test the limits of access restrictions to prove their ability to overcome the obstacles
- Some hackers seek to commit a crime through their actions for some level of personal gain or satisfaction

IT personnel

- These individuals have the easiest access to computerized information, as they are the custodians of this information. In addition to logical access controls, good SoD and supervision help in reducing logical access violations by these individuals.

End-User

- Personnel who often have a broad knowledge of the information within the organization and have easy access to internal resources

Former Employees

- Who have left on unfavorable terms may have access if it was not immediately removed at the time of the employee's termination or if the system has "back doors.

ICT @ Mzuni

Perpetrators in computer crimes

Script kiddies:

- Script kiddies are also known as Skiddies.
- Script kiddies are an unskilled individual who uses existing computer scripts or codes to hack into computers, lacking the expertise to write their own.

Employees (authorized or unauthorized)

- Affiliated with the organization and given system access based on job responsibilities, these individuals can cause significant harm to an organization.
- Therefore, screening prospective employees through appropriate background checks are an important means of preventing computer crimes within the organization.

Third parties

- Vendors, visitors, consultants or other third parties who, through projects, gain access to the organization's resources and could perpetrate a crime

Accidental unaware

- Someone who unknowingly perpetrates a violation

Opportunists

- Where information is inadvertently left unattended or left for destruction, a passerby can access the same

Common attack methods and techniques



Alternation attack:

This occurs when unauthorized modifications affect the integrity of the data or code. A cryptographic hash is a primary defense against alteration attacks.



Botnets

- Short form of Robot network
- Botnets comprise a collection of compromised computers (called zombie computers) running software, usually installed via worms, Trojan horses or back doors
- Examples are Denial-of-service (DoS) attacks, adware, spyware, and spam



Brute force attack

- Attack launched by an intruder, using many of the password-cracking tools available at little or no cost, on encrypted passwords and attempts to gain unauthorized access to an organization's network or host-based systems
- The attacker systematically checks all possible passwords and passphrases until the correct one is found.



War dialing

- Also known as Dial-in penetration attack.
- a technique to automatically scan a list of telephone numbers, usually dialing every number in a local area code to search for modems, computers, bulletin board systems (computer servers) and fax machines .

Common attack methods and techniques



Wardriving

- The act of searching for Wi-Fi wireless networks , usually from a moving vehicle, using a laptop or smartphone



Eavesdropping:

- An intruder gathers the information flowing through the network with the intent of acquiring and releasing the message contents for either personal analysis or for third parties who might have commissioned such eavesdropping.



Piggyba

- The act of following an authorized person through a secured door or electronically attaching to an authorized telecommunications link to intercept and possibly alter transmissions.
- Piggybacking is considered a physical access exposure

ICT @ Mzuni

Social Engineering Attacks

- Social engineering attacks typically involve some form of psychological manipulation, fooling otherwise unsuspecting users or employees into handing over confidential or sensitive data.
- Social engineering takes advantage of the weakness of human factor
- In order to protect your organizations from social engineering by ensuring your staff are well trained

ICT @ Mzuni

Types of social engineering attacks



Honey trap

- Attackers pretend to be romantically or sexually interested in the victim to persuade them to yield sensitive information or money.



Email hacking and contact spamming

- It's in our nature to pay attention to messages from people we know.
- Some criminals try to take advantage of this by commandeering email accounts and spamming account contact lists.



Baiting

- This type of social engineering depends upon a victim taking the bait, not unlike a fish reacting to a worm on a hook.
- The person dangling the bait wants to entice the target into taking action.



Phishing

- Phishing is a well-known way to grab information from an unwitting victim.
- Despite its notoriety, it remains quite successful. The perpetrator typically sends an email or text to the target, seeking information that might help with a more significant crime.



Quid Pro Quo

- An attacker makes random calls and offer a gift or a benefit in exchange for a specific action or piece of Information.

ICT @ Mzuni

Protecting against social engineering

1. **Build a positive security culture**
   - It's essential that your staff are aware of their security responsibilities and report potential phishing attacks as soon as possible, not think they shouldn't say anything because they might get in trouble.

2. **Train your staff**
   - Understand the consequences of social engineering attacks;
   - Are suspicious of unsolicited communications and unknown people;
   - Check whether emails genuinely come from their stated recipient (double-check senders' names and look out for giveaways such as spelling errors and other illiteracies);
   - Don't open suspicious email attachments;
   - Think before providing sensitive information (no one legitimate will ever ask you for your password, for instance);
   - Pay attention to URLs, and 'typosquatting' (sites that look genuine but whose web addresses are subtly different from the legitimate site they're imitating)

ICT @ Mzuni

Protecting against social engineering

III. Implement appropriate technical measures

- Staff training is essential, but it's not everything. You also need to implement wider information security measures so that if attackers do manage to trick users, it's difficult for them to get much further.
    1) Using firewalls, antivirus, anti-malware, whitelisting and spam filters to keep malicious traffic to a minimum;
    2) Applying patches and keeping your systems up to date so that you are not vulnerable to known software and network vulnerabilities;
    3) Using rigid data classification models and privileged access management policies to secure, and control who has access to, sensitive data;
    4) Keeping records of who has access to what information, and who is therefore most at risk; and
    5) Implementing a policy of using strong, unique passwords.

ICT @ Mzuni

Tips for avoiding Social engineering attacks

If it sounds to good to be true, it probably is.

Be wary of threatening, urgent, or demanding, messages

Don’t be afraid to speak up. If something seems out of place or strange, ask your IT team.

https://www.infosectrain.com/blog/cisa-domain-5-protection-of-information-assets/